VERIQTA

The Junior Cybersecurity Interview Bible

Technical Questions, Practical Answers, and Real-World Security Scenarios



VERIQTA

- Core Security Concepts
- Real Interview Questions & Answers
- Hands-On Scenarios and Troubleshooting
- SOC, Cloud, Web, and Endpoint Security
- A Complete 20-Page Interview Preparation Guide

Cybersecurity Fundamentals: 5 Essential Interview Questions

1 What is Cybersecurity?

- Cybersecurity is the practice of protecting systems, data, networks, and applications from unauthorized access, attack, damage, or theft.
- It protects the **confidentiality**, **integrity**, and **availability** of information.



2 Explain CIA (Confidentiality, Integrity, Availability).

- These are the three core security goals for protecting information.
- **Confidentiality:** Only authorized people can access the data.
- **Integrity:** The data remains accurate and is not altered without permission.
- **Availability:** The data and systems are accessiblle when needed.

C Confidentiality	I Integrity	A Availability
Keep data private	Keep data accurate and trusted	Keep data and services accessible

3 What is the Difference Between a Threat, Vulnerability, and Risk?

- **Threat:** A potential cause of harm (e.g., a hacker, malware).
- **Vulnerability:** A weakness that can be exploited (e.g., unpatched software).
- **Risk:** The chance that a threat will exploit a vulnerability and cause harm (e.g., data breach or service outage).

Term	Meaning	Example
Threat	A potential attacker or harmful event.	Hacker targeting your system
Vulnerability	A weakness in a system or configuration.	Unpatched software
Risk	The likelihood and impact of an attack.	Data breach from the unpatched system

4 What is an Attack Surface?

- The attack surface is the total number of entry points an attacker can use to access your systems, data, or network.
- The more exposed services and components you have, the larger the attack surface.



5 What is Defense in Depth?

- A security approach that uses nultiple layers of protection instead of relying on only one control.
- If one layer fails, other layers still reduce the risk.

Layers of Defense (Example)



Interview Scenario

A company exposes an internal database to the internet. What security concerns would you identify?



Key Security Conerns:

- Unauthorized access by external attackers.
- Data breach and theft of sensitive information.
- No network isolation (lack of proper firewall or access control).
- Increased attack surface (database is now publicly reachable).
- Compliance and legal risks (e.g., GDPR, data privacy laws).

Networking Security: 5 Essential Interview Questions

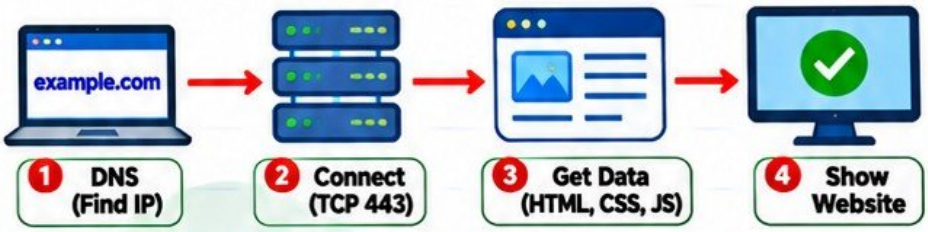
1 TCP versus UDP

- **TCP** (Transmission Control Protocol): Reliable, connection-oriented, ensures data is delivered in order (e.g., web, email, file transfer).
- **UDP** (User Datagram Protocol): Faster, connectionless, does not guarantee delivery (e.g., DNS, video streaming, VoIP).

Feature	TCP	UDP
Connection	Connection-oriented	Connectionless
Reliability	Reliable (guaranteed)	Not guaranteed
Speed	Slower	Faster
Use Cases	Web, email, file transfer	DNS, streaming, VoIP

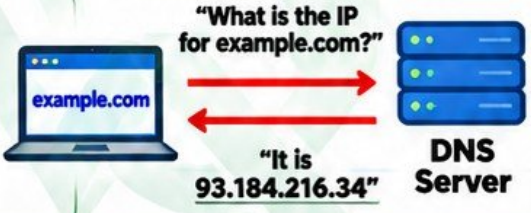
2 What Happens When You Enter a Website Address?

1. Your browser checks DNS to find the server's IP address.
2. It connects to the server using TCP (e.g., port 443 for HTTPS).
3. The server responds and sends the website data.
4. Your browser renders the web page for you.



3 What is DNS, and How Can Attackers Abuse It?

- **DNS** (Domain Name System) translates a website name (e.g., example.com) to an IP address (e.g., 93.184.216.34).
- Attackers can abuse DNS through: DNS spoofing (fake IP), DNS hijacking (redirecting users), and DNS tunneling (hiding malware traffic).



Common DNS Abuses

- DNS spoofing
- DNS hijacking
- DNS tunneling

4 HTTP versus HTTPS

- **HTTP** (Hypertext Transfer Protocol): Sends data in plain text (not secure).
- **HTTPS** (HTTP Secure): Uses TLS/SSL to encrypt data, keeping it private and protected.

HTTP (Insecure)

⚠ http://example.com

- Data is not encrypted
- Vulnerable to eavesdropping and data theft

HTTPS (Secure)

🔒 https://example.com

- Data is encrypted (TLS/SSL)
- Protects logins, personal data, and sensitive information

5 Firewall versus IDS

- **Firewall**: Controls network traffic by allowing or blocking connections based on rules (e.g., IP, port, protocol).
- **IDS** (Intrusion Detection System): Monitors network traffic for suspicious or malicious activity and generates alerts.

Aspect	Firewall	IDS
Main Purpose	Allow or block traffic	Detects suspicious activity
Action	Blocks based on rules	Alerts (does not block)
Example Use	Block unwanted ports (e.g., port 23)	Detect possible attacks (e.g., port scan, brute force)

Practical Commands

`ping example.com`	– Check if a host is reachable.
`nslookup example.com`	– Query DNS and get the IP address.
`ss -tuln`	– Show listening ports and services.

Interview Scenario

A website is unreachable. How would you investigate?

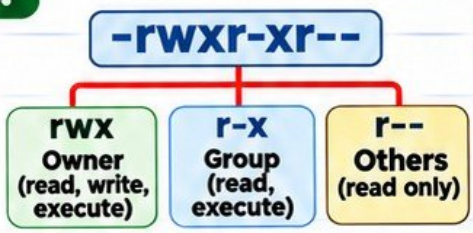
Investigation Steps:

1. Check connectivity: `ping example.com`.
2. Verify DNS resolution: `nslookup example.com`.
3. Check if the service/port is reachable: `ss -tuln`.
4. Review firewall rules and server status.

Linux Security: 5 Essential Interview Questions

1 Explain Linux File Permissions.

- Linux uses permissions to control who can read, write, or execute a file or directory.
- Permissions are for three users: Owner (u), Group (g), and Others (o).



Permission Values

- r = Read (4)
- w = Write (2)
- x = Execute (1)

2 What is the Principle of Least Privilege?

- Give only the minimum access required to perform a task.
- It reduces the risk of misuse, accidental changes, or privilege escalation.



Benefits

- Limits attack impact
- Prevents unauthorized changes
- Improves system security

3 Difference Between Root and a Regular User?

- **Root**: The superuser with full control over the system (e.g., install software, change configs, manage users).
- **Regular User**: A standard account with limited permissions for daily tasks.



Aspect	Root User	Regular User
User ID (UID)	0	≥ 1000
Permissions	Full system access	Limited access
Typical Use	System administration	Daily work (safer)

4 How Do You Investigate Suspicious Processes?

- Check running processes, resource usage, and process details to find unusual or unauthorized activity.
- Look for unknown processes, high resource usage, or unexpected network connections.



Useful Commands

- `ps aux` – List all running processes.
- `top` – View real-time resource usage.
- `lsof -i` – Show processes using network ports.
- `ss -tuln` – Check listening ports.

5 Where Would You Look for Authentication Failures?

- Check system authentication logs for failed login atempts (especially SSH).
- Common log locations:
  - `/var/log/auth.log` (Ubuntu/Debian)
  - `/var/log/secure` (RHEL/CentOS)
- You can also use `journalctl` to query logs.



Example Command

```
journalctl -u ssh -n 20
```

- Shows the last 20 SSH log entries, including failed logins.

Practical Commands

Command	Purpose
`ls -l`	List files with permissions, owner, and group.
`ps aux`	Show all running processes.
`journalctl`	View system logs (e.g., SSH, services).
`ss -tuln`	Show listening network ports and services.

Interview Scenario

Scenario: Multiple failed SSH logins appear in system logs. How would you investigate?

Investigation Steps:

1. Check SSH logs: `journalctl -u ssh`.
2. Identify the source IPs and number of attempts.
3. Check if any login was successful after the failures.
4. Block suspicious IPs (e.g., using a firewall like ufw).
5. Monitor and verify the system is secure.

Windows Security and Active Directory: 4 Interview Questions

1 What is Active Directory, and Why Do Organizations Use It?

- **Active Directory (AD)** is Microsoft's directory service that centrally manages users, computers, and access to resources in a Windows environment.
- Organizations use it for centralized authentication, access control, policy management, and security.



- Users & Groups
- Computers & Devices
- Access Control
- Policies (Group Policy)

2 Explain Authentication Versus Authorization.

- **Authentication:** Confirms your identity (e.g., username and password, MFA).
- **Authorization:** Determines what you are allowed to do after you are authenticated (e.g., read, write, or admin access).



3 What Are Windows Event Logs?

- **Windows Event Logs** are system records that capture important activities, such as logins, logouts, security events, errors, and system changes.
- They help with troubleshooting, security monitoring, and investigating incidents.



Common Event Log Types

- **Security** – Logins, access, and security events.
- **System** – OS and service events.
- **Application** – Application errors and information.

4 What is Group Policy?

- **Group Policy (GPO)** is a feature in Active Directory that lets administrators centrally configure and enforce settings on users and computers.
- It is used to apply security rules (e.g., password policy, software restrictions, firewall settings).



Examples of Group Policy Settings

- Enforce strong password rules.
- Lock screen after inactivity.
- Restrict software installation.
- Configure Windows firewall.

Practical Example



Investigating Repeated Failed Windows Logins:

- Open Event Viewer.
- Go to Windows Logs > Security.
- Filter for Event ID 4625.
- Review the details (user, source IP, logon type, and time).

Important Event IDs

Event ID	Meaning	Use Case
4624	Successful logon	Confirms a user logged in successfully.
4625	Failed logon	Shows an unsuccessful login attempt (e.g., wrong password).

Security Operations Center: 4 Interview Questions

1 What Does a SOC Analyst Do?

- Monitors security systems and alerts for signs of threats.
- Investigates suspicious activity, assesses the risk, and responds.
- Helps detect, contain, and report security incidents.



Key Tools (Examples)

SIEM (e.g., Splunk)
EDR (e.g., CrowdStrike)
Log Analysis
Threat Investigation

2 Explain Tier 1 Versus Tier 2 Analyst Responsibilities.

Aspect	Tier 1 Analyst	Tier 2 Analyst
Main Focus	Monitor and triage alerts	Deep investigation and analysis
Typical Tasks	Alert review, initial validation, basic response	Threat hunting, root cause analysis, containment
Skill Level	Junior / Entry-level	Intermediate
Outcome	Escalate confirmed or complex issues	Resolve, contain, and provide recommendations



3 What is a Security Alert?

- A notification from a security tool (e.g., SIEM, EDR, firewall) that something unusual or potentially malicious was detected.
- It indicates a possible security issue that needs review and investigation.



4 Difference Between a Security Event and an Incident?

- **Security Event:** Any observable activity in a system (e.g., a login, file access, or alert). It may be normal or suspicious.
- **Security Incident:** A confirmed or likely harmful event that impacts the confidentiality, integrity, or availability of a system or data.

SOC Workflow



Interview Scenario



An endpoint generates a suspicious PowerShell alert. What would you do?

Your Approach (Key Steps)

1. Review the alert details (user, host, command, time).
2. Check the PowerShell command for malicious behavior (e.g., encoded command, download, or remote execution).
3. Verify the process and user activity on the endpoint (e.g., via EDR or system logs).
4. Determine the impact and contain if needed (e.g., isolate host).
5. Document findings and escalate if it's a confirmed threat.

SIEM and Log Analysis: 4 Interview Questions

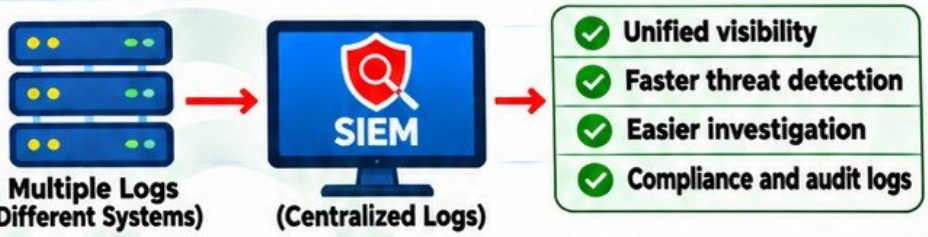
1 What is Security Information and Event Management (SIEM)?

- A SIEM is a centralized platform that collects, normalizes, analyzes, and correlates security logs from multiple systems.
- It helps detect threats, raise alerts, and support incident investigation and response.



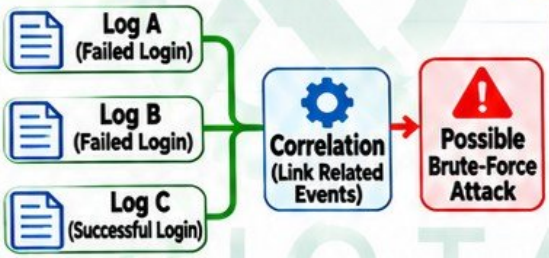
2 Why Do Organizations Centralize Security Logs?

- To get a complete, real-time view of security activity across all systems.
- To detect and respond to threats faster.
- To simplify investigation, compliance, and reporting (e.g., ISO 27001, NIST).



3 What is Log Correlation?

- Log correlation is the process of linking related log events from different sources to spot meaningful patterns, attacks, or suspicious activity.
- Example: Multiple failed logins followed by a successful login from the same IP.



4 What is a False Positive?

- A false positive is a security alert that looks like a threat but is actually a harmless or legitimate activity.
- Example: A user logging in from a new device may trigger an alert, but it can be a legitimate login.

Example: Multiple Failed Logins Followed by a Successful Login



- Several failed login attempts from the same IP address.
- A successful login shortly after.
- This pattern may indicate a brute-force attack where the attacker eventually guessed the correct password.

Key Takeaway

- Investigate the source IP and user.
- Check if it's a legitimate user.
- Review related activity (time, location, commands, file access).

Practical Task

Identify suspicious activity from the authentication log below.



Time (UTC)	User	IP Address	Status
10:01:12	jdoe	203.0.113.45	Failed
10:01:25	jdoe	203.0.113.45	Failed
10:01:39	jdoe	203.0.113.45	Failed
10:02:10	jdoe	203.0.113.45	Failed
10:03:05	jdoe	203.0.113.45	Successful

Answer / Analysis

- There are 4 failed login attempts followed by 1 successful login from the same IP (203.0.113.45).
- This pattern is suspicious and suggests a possible brute-force attack.
- Next steps: verify the user, check account activity, and review related SIEM alerts and logs.

Malware and Endpoint Security: 4 Interview Questions

1 What is Malware?

- Malware (malicious software) is software designed to harm, disrupt, steal data, or gain unauthorized access to a system.
- It can affect confidentiality, integrity, and availability of data and systems.



Common Impacts

- Steal sensitive data
- Damage or encrypt files
- Give attackers remote access
- Disrupt business operations

2 Compare Viruses, Worms, Trojans, and Ransomware.

Type	What It Is	How It Spreads	Main Impact
Virus	Malware that attaches to legitimate files.	User action (e.g., running an infected file).	Infects and damages files.
Worm	Self-replicating malware that spreads automatically.	Across networks without user action.	Spreads quickly and can overwhelm systems.
Trojan	Malware that looks legitimate but performs a harmful action.	Tricked user (e.g., fake app or installer).	Gives attackers unauthorized access (backdoor).
Ransomware	Malware that encrypts files and demands payment.	Phishing, malicious links, or infected files.	Locks data and demands ransom to restore access.

3 What is Endpoint Detection and Response (EDR)?

- EDR is a security solution that monitors and collects activity data from endpoints (e.g., laptops, desktops, servers) to detect, investigate, and respond to threats.
- It provides real-time visibility, threat detection, and response actions (e.g., isolate a device, stop a process).



Key Capabilities

- Continuous endpoint monitoring
- Detects suspicious behavior
- Collects incident evidence (logs, files)
- Enables response (e.g., isolate, block)

4 Signature-Based vs Behavioral Detection.

Aspect	Signature-Based Detection	Behavioral Detection
How It Works	Matches files or activity to known malware signatures (hashes, patterns).	Looks for suspicious or abnormal behavior (e.g., unusual process, privilege use).
Strength	Fast and effective for known threats.	Can detect new and unknown (zero-day) threats.
Limitation	Misses new, modified, or unknown malware.	May generate more false positives.
Example	Blocks a known ransomware file hash.	Flags a process that attempts to encrypt many files.

Interview Scenario



An employee opens a suspicious email attachment. What should you do asa SOC analyst?

Troubleshooting: Evidence to Collect Before Remediation

1. Email details (sender, subject, attachment, headers).
2. Endpoint evidence (processes, running programs, network connections, file hashes).
3. EDR/SIEM alerts and relevant logs (e.g., Windows Event Logs).
4. Indicators of Compromise (IOCs) such as file hash, domain, or IP.
5. Scope of impact (other affected users or systems).

Phishing and Social Engineering: 3 Interview Questions

1 What is Phishing, and How Does It Work?

- Phishing is a social engineering attack that tricks people into revealing sensitive information (e.g., passwords, bank details) or performing a harmful action (e.g., downloading malware).
- It works by sending a deceptive message (usually email) that looks legitimate and creates urgency, curiosity, or fear.



How It Typically Works

1. Attacker creates a fake but realistic message (e.g., bank, IT, HR).
2. The message contains a malicious link or attachment.
3. The user clicks the link or opens the attachment.
4. The attacker steals data or installs malware on the device.

2 Difference Between Phishing, Spear Phishing, and Business Email Compromise.

Type	What It Is	Target	Example
Phishing	A broad, generic attack that tries to trick many people at once.	General users (large group)	A fake "Microsoft 365" password reset email.
Spear Phishing	A targeted phishing attack customized for a specific person or role.	A specific individual (e.g., finance staff)	An email to a finance officer with a fake invoice.
Business Email Compromise (BEC)	A more advanced attack that impersonates a trusted person (e.g., CEO, vendor) to steal money, data, or cause fraud.	Organizations (e.g., executives, finance, suppliers)	A fake email from the CEO requesting an urgent payment to a new account.

3 How Would You Investigate a Suspicious Email?

- Do not click links or open attachments.
- Check the sender's email address (spelling, domain, and legitimacy).
- Inspect the email headers (e.g., Received, SPF, DKIM, DMARC).
- Analyze links safely (e.g., copy and check on VirusTotal or a sandbox).
- Check for red flags (urgent language, unexpected requests, poor grammar).



Investigation Checklist

- ✓ Verify sender identity and domain.
- ✓ Review full email headers.
- ✓ Analyze links and attachments safely.
- ✓ Look for social engineering cues (urgency, fear, unusual requests).
- ✓ Report the email to the security team (SOC/IT) with your findings.

Practical Exercise: Examine the Email

From: Microsoft Support <support@micros0ft365.com>

Subject: Urgent: Verify Your Account Now

Your Microsoft 365 account will be suspended today due to unusual activity. Click the link below to verify your identity:

https://microsoft365-security-login.com

Failure to act within 2 hours will result in permanent account loss.

Warning Signs

- Suspicious domain (micros0ft365.com uses "0" not "o").
- Creates urgency ("suspended today").
- Requests account verification via a link.
- Not from an official Microsoft domain (microsoft.com).

Security Reminder

Never execute attachments or follow suspicious links during initial analysis.

Vulnerability Management: 3 Interview Questions

1 What is Vulnerability Scanning?

- Vulnerability scanning is an automated process that checks systems, applications, and networks for known security weaknesses (vulnerabilities).
- It identifies, lists, and often rates the risks so they can be fixed before attackers exploit them.



Common Scan Targets

- Servers (Linux/Windows)
- Applications (Web/API)
- Network devices (Routers, Firewalls)
- Cloud resources (e.g., AWS, Azure)

2 Vulnerability Assessment vs Penetration Testing.

Aspect	Vulnerability Assessment	Penetration Testing
Purpose	Identifies and reports security weaknesses.	Actively explores and tries to exploit weaknesses to prove real-world impact.
Approach	Automated tools + analysis (primarily non-intrusive).	Simulated attack by a security tester (authorized and controlled).
Outcome	A list of vulnerabilities with risk ratings and recommended fixes.	Evidence of exploitation, impact, and detailed remediation advice.
Frequency	Regular (e.g., monthly or quarterly).	Less frequent (e.g., annually or before major releases).

3 What is CVSS, and How Should Severity Influence Prioritization?

- CVSS (Common Vulnerability Scoring System) is a standardized framework that rates the severity of a vulnerability on a score from 0.0 to 10.0, based on its exploitability impact, and other factors.
- Severity should guide prioritization — fix higher-risk (Critical/High) vulnerabilities first, especially those that are exploitable and business-critical (e.g., internet-facing systems, sensitive data).



CVSS SCORE
(0.0 – 10.0)

CVSS Severity Levels

Score (CVSS)	Severity
9.0 – 10.0	Critical
7.0 – 8.9	High
4.0 – 6.9	Medium
0.1 – 3.9	Low
0.0	None

Example Scenario



A critical vulnerability (CVSS 9.8) is found on an internet-facing server.

- Risk: High chance of remote exploitation.
- Impact: Could give an attacker full control of the server.
- Action: Treat as an urgent, high-priority fix.

Vulnerability Management Workflow

Discover	Validate	Prioritize	Remediate	Verify
Find vulnerabilities (e.g., scan).	Confirm the issue and rule out false positives.	Rank by severity (CVSS), impact, and exposure.	Fix the vulnerability (e.g., patch, config change).	Retest to confirm the fix is effective.

Identity and Access Management: 3 Interview Questions

1 What is Identity and Access Management (IAM)?

- IAM is a security framework that manages digital identities (users, devices, and services) and controls their access to systems, applications, and data.
- It ensures the right person has the right access to the right resource at the right time.



Key IAM Functions

- Create and manage users and identities.
- Control access to resources (apps, data, systems).
- Enforce security policies (e.g., MFA, password rules).
- Monitor and review access regularly.

2 What is Multifactor Authentication (MFA)?

- MFA is a security method that requires two or more verification factors to confirm a user's identity before granting access.
- It reduces the risk of unauthorized access, even if a password is compromised.



Something You Know (e.g., Password) + Something You Have (e.g., OTP App) + Something You Are (e.g., Fingerprint)

3 Explain Role-Based Access Control (RBAC).

- RBAC is an access control method that grants permissions based on a user's role (e.g., Admin, Analyst, Developer) rather than individual access.
- It simplifies access management, reduces errors, and supports the principle of least privilege.

RBAC (Example)



Interview Scenario



An employee switches from the IT team to the finance team but still has administrative permissions on production systems.

What is the risk, and what should you do?

Key Takeaway

- This is an access governance issue (excessive and unnecessary privilege).
- Immediate action: revoke the admin permissions.
- Update the user's role to match their new responsibilities (e.g., Finance).
- Conduct regular access reviews to find and remove stale or excessive access.

Practical Lesson



Least Privilege and Periodic Access Reviews

- Grant only the minimum access needed to do the job (least privilege).
- Review user access regularly (e.g., monthly or quarterly).
- Remove unused, excessive, or outdated permissions (e.g., after role changes, team exits, or project completion).

Cloud Security: 3 Interview Questions

1 What is the Cloud Shared Responsibility Model?

- It defines the security responsibilities between the cloud provider (e.g., AWS) and the customer (you) in the cloud.
- The provider secures the cloud infrastructure, while you secure your data, applications, and access within the cloud.



Cloud Provider Responsibility (AWS)

- Security of the cloud (infrastructure).
- Physical security, hardware, and network.
- Availability and core cloud services (e.g., EC2, S3, RDS).

Customer Responsibility (You)

- Security in the cloud.
- Data protection (encryption, access).
- Identity and access management (IAM).
- Application, OS, and configuration security.

2 How Do You Secure an AWS S3 Bucket?

- Use IAM policies and bucket policies to control who can access the bucket.
- Block public access (Enable "Block Public Access").
- Encrypt data (SSE-S3 or SSE-KMS).
- Enable access logging (S3 access logs or CloudTrail).
- Use versioning and lifecycle policies (optional, for protection and cost control).



AWS S3 (Bucket)

S3 Security Configuration (Example)

Access:	Restrict with IAM and bucket policies.
Public Access:	Block all public access.
Encryption:	Enable SSE-S3 or SSE-KMS.
Logging:	Turn on access logs (CloudTrail or S3 logs).
Versioning:	Enable (optional).

3 What is the Purpose of Cloud Security Groups?

- A cloud security group acts as a virtual firewall that controls inbound and outbound traffic to cloud resources (e.g., EC2).
- It uses allow rules (e.g., allow SSH on port 22) to permit only the required traffic.



Security Group

Common Examples

- Allow SSH (port 22) from your IP only.
- Allow HTTP/HTTPS (ports 80/443) for web servers.
- Block all other unnecessary traffic (default deny).

Interview Scenario



A storage bucket (S3) is accidentally made publicly accessible.

What steps would you take to investigate and fix the issue?

Cloud Security Checklist

Access	Use IAM and bucket policies, enforce least privilege, and block public access.
Encryption	Encrypt data at rest (SSE-S3/SSE-KMS) and in transit (HTTPS/TLS).
Logging	Enable S3 access logging and CloudTrail to track who accessed what and when.
Exposure	Regularly check for public exposure (e.g., AWS Config, Security Hub, or Access Analyzer).

Web Application Security: 3 Interview Questions

1 Key Web Application Security Concepts

Question	Answer (Concise Explanation)	Example / Impact
 What is SQL Injection?	A web attack that injects malicious SQL code into an application's input to manipulate the database.	E.g., ' OR 1=1 -- may bypass login and give unauthorized access to data.
 What is Cross-Site Scripting (XSS)?	A vulnerability that allows an attacker to inject and run malicious scripts (e.g., JavaScript) in a user's browser.	E.g., stealing session cookies, redirecting users to a fake site, or defacing a page.
 What is Broken Access Control?	A flaw that allows users to access resources or data they are not authorized to access.	E.g., a user viewing or modifying another user's account by changing a URL ID (e.g., id=1001 to id=1002).

2 How to Reduce Risks: Key Security Controls

Control	How It Works	Example / Benefit
 Input Validation	Checks and sanitizes user input to ensure it matches the expected format, type, and length.	Allow only valid data (e.g., numbers only for an ID) to block malicious input (e.g., SQL code or scripts).
 Parameterized Queries	Uses prepared statements to separate user input from the SQL command, preventing SQL injection.	E.g., SELECT * FROM users WHERE id = ? instead of building SQL with string concatenation.
 Authorization Checks	Verifies that the logged-in user has the right permissions to access the requested resource.	E.g., ensure a user can only view or modify their own account data (not another user's).

3 Interview Scenario



A user can access another user's account data by changing an ID in the URL (e.g., /account?id=1002).

- What is the issue, and how would you fix it?

Key Takeaways

- Use input validation to accept only expected and safe input.
- Use parameterized queries to prevent SQL injection.
- Enforce authorization checks (e.g., RBAC) to ensure users access only their own data.
- Regularly test for common web vulnerabilities (e.g., using OWASP Top 10).

Cryptography and Data Protection: 3 Interview Questions

1 What is Encryption?

- Encryption converts data into an unreadable format (ciphertext) using an algorithm and a key.
- Only authorized users with the correct key can decrypt and read the data.
- It protects data in transit and at rest (e.g., files, emails, databases).



Plain Text → Encrypted (Ciphertext)

Key Terms

- **Plaintext:** Original, readable data.
- **Ciphertext:** Encrypted, unreadable data.
- **Key:** Used to encrypt and decrypt.
- **Algorithm:** The method used for encryption.

2 Compare Symmetric and Asymmetric Encryption.

	Symmetric Encryption	Asymmetric Encryption
Keys	Uses the same key for encryption and decryption.	Uses a public and private key pair (different keys).
Speed	Faster and less complex.	Slower and more complex.
Use Cases	Bulk data, internal systems, secure communication.	Secure key exchange, digital signatures, external communication.
Examples	AES, ChaCha20.	RSA, ECC.

3 What is the Difference Between Hashing and Encryption?

Feature	Hashing	Encryption
Purpose	Creates a fixed-size digest (irreversible).	Converts data to ciphertext (reversible with the key).
Reversibility	Not reversible.	Reversible (with correct key).
Key Required	No (uses hash function).	Yes (uses encryption key).
Common Uses	Password storage, data integrity, checksums.	Data in transit, data at rest, confidential communication.
Examples	SHA-256, bcrypt, Argon2.	AES, RSA, ChaCha20.

4 Practical Examples

- **TLS:** Encrypts data between your browser and a website.
- **Password hashing:** Stores hashed passwords (e.g., bcrypt).
- **Encrypted storage:** Protects files and disks (e.g., EBS, BitLocker).

5 Beginner Mistake

Assuming Base64 encoding provides security.

- Base64 only encodes data (looks like text).
- It is NOT encryption.
- Anyone can decode it easily.

Base64 Example

Hello World!
↓
SGVsbG8gV29ybGQh
(still readable)

Use encryption for real security.

Incident Response: 4 Interview Questions

1 What are the Main Phases of Incident Response?

- A structured process to handle, contain, remove, and recover from a security incident.
- The main phases are: Preparation, Detection and Analysis, Containment, Eradication, Recovery, and Lessons Learned.



The 6 Phases (Overview)

- **Preparation:** People, tools, and plans.
- **Detection and Analysis:** Find and confirm the incident.
- **Containment:** Stop the spread and limit impact.
- **Eradication:** Remove the root cause (e.g., malware, backdoor).
- **Recovery:** Restore normal operations safely.
- **Lessons Learned:** Review, improve controls, and update the plan.

2 What is Incident Containment?

- Actions taken to stop the incident from spreading and reduce further damage.
- Examples: isolate an infected host, block a malicious IP, disable a compromised account, or restrict access.



CONTAINMENT
(Stop the Spread)

Containment Examples

- Isolate the affected workstation (from the network).
- Block malicious IPs/domains (firewall).
- Disable or reset a compromised account.
- Apply temporary access restrictions (e.g., read-only).

3 What is the Difference Between Eradication and Recovery?

Aspect	Eradication	Recovery
Purpose	Remove the cause of the incident from the environment.	Restore normal and secure operations after the threat is removed.
What It Does	Eliminates malware, malicious files, unauthorized access, and other threats.	Return systems, data, and services to a known good state.
Example	Delete ransomware, close the entry point, and patch the vulnerability.	Restore clean backups and bring systems back online.

4 Why is Evidence Preservation Important?

- Maintains the integrity and reliability of evidence.
- Supports a full investigation (e.g., root cause, scope, and impact).
- May be required for legal, regulatory, or disciplinary action.



EVIDENCE
PRESERVATION

Key Evidence to Preserve

- System and application logs.
- Malware samples and file hashes.
- Memory and disk images (forensics).
- Network captures (e.g., PCAP).
- Timeline of activities (who, what, when).

Incident Scenario



A workstation is suspected of ransomware activity (files are encrypted, and a ransom note is displayed).

What immediate actions should you take?

Incident Response Workflow



MITRE ATT&CK and Threat Intelligence: 3 Interview Questions

1 What is the MITRE ATT&CK Framework?

- A globally recognized knowledge base that describes real-world adversary behavior.
- It catalogs the tactics, techniques, and procedures (TTPs) used by attackers across the attack lifecycle.
- Used for threat detection, analysis, hunting, and incident response.



Key Facts

- Created by MITRE (a non-profit organization).
- Focuses on attacker behaviors (not just specific tools).
- Organized by tactics (goals) and techniques (how they are done).
- Widely used in SOC, threat hunting, and risk assessment.

2 What is the Difference Between Tactics and Techniques?

Aspect	Tactic	Technique
Meaning	The attacker's high-level goal or objective ("why").	The specific method used to achieve the tactic ("how").
Scope	Broad and strategic (e.g., gain access).	Specific and actionable (e.g., brute force, phishing).
Example	Initial Access (TA0001).	Valtial Accounts (T1078), Phishing (T1566).

Common MITRE ATT&CK Tactics (Examples)

- TA0001 Initial Access – Get into the system.
- TA0002 Execution – Run malicious code.
- TA0003 Persistence – Keep access.
- TA0004 Privilege Escalation – Gain higher permissions.
- TA0006 Credential Access – Steal credentials.

3 What are Indicators of Compromise (IOCs)?

- Observable pieces of evidence that can indicate a possible security compromise.
- They help identify malicious activity, known threats, or attacker infrastructure.
- IOCs are used in detection, alerting, and threat hunting.

IOCs (Examples)

- Malicious IP address
- Suspicious domain
- File hash (e.g., SHA256)
- Malware filename
- Unusual process name

Important Distinction

An indicator alone does not prove compromise.

- It is a signal that requires further analysis and context (e.g., logs, behavior, correlation).
- IOCs can be legitimate in some cases (e.g., a shared IP or a flagged domain).

Practical Example: Map Suspicious Login Activity to ATT&CK



- Suspicious Event: Multiple failed logins from an unfamiliar IP, followed by a successful login.
- Mapped Tactic: Credential Access (TA0006).
- Mapped Technique: Brute Force (T1110) or Valid Accounts (T1078) (if stolen credentials are used).

Key Takeaways

- MITRE ATT&CK = structured view of attacker behavior.
- Tactics = goals; Techniques = methods.
- IOCs = clues, not definitive proof.
- Use ATT&CK mappings to improve detection, response, and threat hunting.

Practical Security Commands: 5 Interview Tasks

1 ip addr or ipconfig: Inspect Network Configuration.



Command & Example	Expected Result (Sample)	Troubleshooting Use

Linux:
`$ ip addr`
Windows:
`C:\> ipconfig`
	Linux (sample):
	`inet 192.168.1.10/24 dev eth0`
	Windows (sample):
	`IPv4 Address . . . . . : 192.168.1.10`
		■ Verify IP address, interface status, and network connectivity.
		■ Detect abnormal IP changes (e.g., suspicious or unauthorized addresses).

2 ss -tuln: Identify Listening Ports on Linux.



Command & Example	Expected Result (Sample)	Troubleshooting Use
`$ ss -tuln`	Netid State Local Address:Port tcp LISTEN 0.0.0.0:22 tcp LISTEN 0.0.0.0:80 tcp LISTEN 127.0.0.1:5432	■ List all open (listening) ports and services. ■ Identify unexpected or unauthorized services (e.g., unknown port listening).

3 nslookup: Investigate DNS Resolution.



Command & Example	Expected Result (Sample)	Troubleshooting Use

`$ nslookup veriqta.com`	`Server: 8.8.8.8`
	`Address: 8.8.8.8#53`
	`Non-authoritative answer:`
	`Name: veriqta.com`
	`Address: 104.21.16.1`
		■ Check if a domain resolves correctly and to the expected IP.
		■ Help detect DNS hijacking, misconfiguration, or malicious domain changes.

4 journalctl: Inspect Linux System Logs.



Command & Example	Expected Result (Sample)	Troubleshooting Use
`$ journalctl -n 10`	Nov 06 10:15:23 server sshd[1123]: Accepted password for user admin from 192.168.1.50 port 53426	■ View and analyze system logs (e.g., authentication, service, errors). ■ Investigate suspicious activity (e.g., repeated failed logins).

5 Get-WinEvent: Query Windows Events Using PowerShell.



Command & Example	Expected Result (Sample)	Troubleshooting Use
`PS> Get-WinEvent -LogName Security -MaxEvents 5`	TimeCreated Id Level Message 11/06 10:20:14 4624 Info An account was successfully logged on.	■ Query and review Windows event logs (e.g., logon, process, policy). ■ Detect suspicious logons, privilege changes, or other security events.

Key Takeaways

- Know the purpose of each command and read the output.
- Use them to verify normal behavior and spot anomalies.
- Combine network, DNS, and log checks for faster incident investigation.

Scenario-Based Interview: 5 Real Security Problems

Identify (The Problem) → Collect Evidence → Assess Impact → Safe Response → Verify Result

1 Scenario 1: Repeated Failed Login Attempts.



Identify	Collect Evidence	Assess Impact	Safe Response	Verify Result
■ Multiple failed logins to the same account (e.g., in logs, SIEM, or alerts).	■ Auth logs (e.g., /var/log/auth.log or Windows Event 4625). ■ Source IPs, timestamps, username, attempt count.	■ Possible brute-force attack. ■ Risk of account takeover if successful.	■ Temporarily lock the account. ■ Block the malicious IP (e.g., firewall/SG). ■ Enable/confirm MFA and alert the user.	■ No further failed attempts. ■ Account is secure. ■ Monitoring/alerts in place.

2 Scenario 2: Suspicious Outbound Network Connections.



Identify	Collect Evidence	Assess Impact	Safe Response	Verify Result
■ Unusual or unauthorized outbound traffic (e.g., to unknown or high-risk IPs/ domains).	■ Network flow logs (e.g., netstat/ss, firewall, EDR, or SIEM). ■ Destination IP/domain, process name, user, timestamp, and volume.	■ Possible data exfiltration or command-and-control (C2) communication.	■ Block the suspicious IP/domain. ■ Isolate the affected host. ■ Investigate the process and remove any threat.	■ Outbound traffic stops. ■ No reoccurrence in logs. ■ System is clean and monitored.

3 Scenario 3: Unexpected Administrator Privileges.



Identify	Collect Evidence	Assess Impact	Safe Response	Verify Result
■ A user has administrator or elevated privileges without a valid business reason.	■ User and group membership (e.g., `getent group`, `id`, or `net user /domain`). ■ Change logs (e.g., Windows Event 4728/4732, IAM audit logs).	■ High risk of unauthorized system changes, data access, or full system compromise.	■ Remove unauthorized privileges immediately. ■ Review who granted the access and why. ■ Enforce least privilege and approval workflows.	■ User has only required access. ■ No unexpected admin accounts. ■ Access changes are logged and documented.

4 Scenario 4: Malware Detected on an Employee Laptop.



Identify	Collect Evidence	Assess Impact	Safe Response	Verify Result
■ Antivirus/EDR alert, unusual behavior (e.g., high CPU, unknown process), or a suspicious file.	■ EDR/antivirus alert details (malware name, file path, hash). ■ System logs, process list (e.g., ps aux, tasklist), and file metadata.	■ Potential data theft, system control, or spread to other devices on the network.	■ Isolate the laptop from the network. ■ Remove the malware (e.g., AV/EDR or reimage). ■ Check for persistence and additional infection.	■ No malware detected on rescan. ■ System is stable and patched. ■ Normal network access is restored.

5 Scenario 5: Sensitive Cloud Storage Exposed Publicly.



Identify	Collect Evidence	Assess Impact	Safe Response	Verify Result
■ A cloud storage bucket (e.g., AWS S3) is publicly accessible ("Public" or "Everyone" access enabled).	■ Cloud configuration (e.g., AWS S3 bucket policy, ACL, or Access Analyzer). ■ Audit logs (e.g., CloudTrail) showing access and changes.	■ Unauthorized access to sensitive or confidential data; potential data breach and compliance risk.	■ Remove public access (deny public ACLs/policies). ■ Restrict access to specific users, roles, or VPC. ■ Enable encryption and access logging.	■ Bucket is no longer public. ■ Access is limited and logged. ■ Encryption and monitoring are active.

Key Takeaways

- ✓ Use a structured approach: Identify → Collect Evidence → Assess Impact → Respond → Verify.
- ✓ Always preserve evidence and document your actions.
- ✓ Focus on containment, minimizing impact, and preventing recurrence.

Junior Cybersecurity Mock Interview: 10 Questions

A mixed technical assessment with short answers and interviewer reasoning.

#	Interview Question	Concise Answer	Why Interviewers Expect This
1	What is the CIA triad?	Confidentiality, Integrity, and Availability.	The core security principles: keep data private (confidentiality), accurate (integrity), and accessible (availability).
2	What is the difference between authentication and authorization?	Authentication verifies who you are; authorization determines what you can do.	Authentication confirms identity (e.g., password, MFA). Authorization grants permissions and access levels (e.g., read, write, admin).
3	What is the difference between TCP and UDP?	TCP is reliable and connection-oriented; UDP is faster, connectionless, and more lightweight.	TCP ensures ordered, error-checked delivery (e.g., HTTP, SSH). UDP is faster with lower overhead, used for real-time traffic (e.g., DNS, video, VoIP).
4	How do you detect a phishing email?	Check the sender, look for suspicious links, poor grammar, urgent requests, and verify through an official channel.	Phishing often uses spoofed senders, malicious links, and social engineering to steal credentials. Verification and user awareness reduce the risk.
5	What do Linux permissions represent?	They control who can read (r), write (w), and execute (x) a file or directory.	Linux uses a permission model (owner, group, others) and can be viewed with "ls -l" (e.g., -rwxr-x---). It helps enforce least privilege and prevent unauthorized access.
6	What is a SIEM alert, and what would you do when you get one?	A SIEM alert flags suspicious or abnormal activity; I would investigate, validate, assess impact, and escalate if needed.	SIEM (Security Information and Event Management) collects and analyzes logs to detect potential threats (e.g., failed logins, unusual access, malware activity).
7	What is IAM, and why is MFA important?	IAM manages digital identities and access to resources; MFA adds an extra verification step to prevent unauthorized access.	IAM ensures the right users have the right access (least privilege). MFA (e.g., password + OTP or app) significantly reduces the risk of account compromise.
8	How do you prioritize vulnerabilities?	Use a risk-based approach (e.g., CVSS score, asset criticality, and exposure) to fix the highest-risk issues first.	Combine severity (CVSS), business impact (critical assets), and exploitability (e.g., internet-facing) to focus on what is most likely to be abused.
9	What are the main phases of incident response?	Preparation, Detection and Analysis, Containment, Eradication, Recovery, and Lessons Learned.	A structured process to handle, remove, and recover from security incidents while improving future defenses.
10	What is a cloud security misconfiguration, and give an example?	A setup error that unintentionally creates risk, e.g., a cloud storage bucket (S3) made publicly accessible.	Common misconfigurations include public access, open security groups, or overly permissive IAM roles. They can expose sensitive data and should be found and fixed with regular reviews and automated checks.

Key Takeaways

- Know the core concepts, give clear and concise answers.
- Use practical examples (e.g., commands, tools, real scenarios).
- Show security thinking: identify risks, assess impact, and recommend a safe action.

Final Interview Challenge: Investigate a Security Incident

Incident Overview



A company detects multiple failed logins, a successful login from an unfamiliar IP address, and unusual access to sensitive files.

Your Role



Junior SOC Analyst: Investigate, analyze, and recommend a response.

Investigation Goals

- Build a timeline of events.
- Analyze logs and suspicious activity.
- Determine if the account was compromised.
- Assess the impact and risk.
- Recommend actions and escalate.

Event Timeline (Key Events)

Time (UTC)	Event
2026-11-05 08:14:21	Multiple failed login attempts (x7) for user: jdoe.
2026-11-05 08:19:03	Successful login for jdoe from unfamiliar IP 185.199.108.45.
2026-11-05 08:26:47	Access to sensitive files in \\FileServer\\Finance (3 files).
2026-11-05 08:35:10	Large file download (78 MB) from the Finance folder.

Sample Authentication Logs

Timestamp	User	IP Address	Result
2026-11-05 08:14:21	jdoe	102.88.16.10	Failed
2026-11-05 08:14:46	jdoe	102.88.16.10	Failed
2026-11-05 08:18:55	jdoe	102.88.16.10	Failed
2026-11-05 08:19:03	jdoe	185.199.108.45	Success
2026-11-05 08:26:47	jdoe	185.199.108.45	File Access
2026-11-05 08:35:10	jdoe	185.199.108.45	File Download

Suspicious IP Activity

IP Address	185.199.108.45
Location	Unknown / Foreign (RU)
ISP / ASN	Cloud Provider (AS14061)
Reputation	Flagged: High Risk (Brute force, credential abuse)

File-Access Evidence (File Server Logs)

Timestamp	User	Action	File Path
2026-11-05 08:26:47	jdoe	Open	\\FileServer\\Finance\\Q3_Results.xlsx
2026-11-05 08:29:12	jdoe	Open	\\FileServer\\Finance\\Payroll.xlsx
2026-11-05 08:35:10	jdoe	Download	\\FileServer\\Finance\\Payroll.xlsx (78 MB)

Five Investigation Questions

1. What is the likely security incident?
2. What evidence shows the account was compromised?
3. What is the potential impact?
4. What immediate actions should be taken?
5. Should this be escalated, and to whom?

Model Answers (with Supporting Evidence)

1. **Likely security incident:** Account compromise via brute-force, followed by unauthorized access and data exfiltration.
2. **Evidence:** Multiple failed logins (08:14–08:18), a successful login from unfamiliar IP 185.199.108.45, and subsequent access to sensitive files.
3. **Impact:** Potential data breach (financial and payroll data), regulatory risk, and possible further unauthorized access.
4. **Immediate actions:** Disable the jdoe account, block IP 185.199.108.45 at the firewall/EDR, preserve logs, and check for other affected accounts.
5. **Escalate: Yes.** Escalate to the SOC Lead and Incident Response Team (IRT) for full containment, eradiation, and data breach assessment.

Incident Escalation Report (Summary)



Title: Suspected Account Compromise and Data Access

Severity: High

Affected User: jdoe

Detected: 2026-11-05 08:14 UTC

Summary: Multiple failed logins, a successful login from unfamiliar IP (185.199.108.45), and unauthorized access and download of sensitive finance files (78 MB).

Recommended Next Steps

- **Contain:** Disable account and block the IP.
- **Investigate:** Full log review and threat hunting (EDR, SIEM, email, other accounts).
- **Assess:** Confirm data exposure and scope.
- **Remediate:** Reset credentials, enforce MFA, and review access permissions.
- **Report:** Escalate to IRT and management for further action.